

Security Incident Response Plan

For Fast Food Restaurant Digital Systems

Table of Contents

[Introduction](#)

[System Overview](#)

[Architecture Model](#)

[Incident Response Procedures](#)

[Security Incident confirmation](#)

[Assess Initial Impact](#)

[Escalate to ISO](#)

[Support P3/P4 Data System Incident Response Activities](#)

[Remediation for P1 Systems](#)

[Appendix A - PCI Procedures](#)

[Appendix B - Reporting Requirements for Credit Card Companies](#)

I. Introduction

This Security Incident Response Plan (IRP) outlines the procedures for detecting, analyzing, and responding to cybersecurity incidents affecting digital systems in fast food restaurant environments. The primary goal is to provide technical staff with effective tools and clear steps to minimize operational disruptions, protect customer data, and ensure compliance with industry security standards and regulations.

This plan is designed to help teams supporting systems that must comply with the Minimum Security Standard for Electronic Equipment (MSSEI) or similar policies. By following this IRP, restaurants can reduce the negative impact of security incidents and maintain smooth, secure, and efficient operations.

II. System Overview

Business and Technical Functions Covered

This IRP applies to the following core systems and processes typically found in modern fast food restaurants:

Customer Ordering Platforms: *Mobile ordering apps, web-based order systems, and in-store self-service kiosks.*

Point-of-Sale (POS) Systems: *Devices and software handling customer payments and transaction records.*

Operational Technology (OT) & IoT Devices: *Smart kitchen appliances (e.g., fryers, ovens, grills), inventory management sensors, temperature monitors, and kitchen display systems.*

Inventory and Supply Chain Management: *Systems and sensors tracking ingredient levels, deliveries, and storage conditions.*

Employee Management Tools: *Scheduling systems and internal communication platforms.*

Customer Data Management: *Databases storing order history, loyalty program information, and personal details.*

A. System Hardware Inventory

<i>Device Type</i>	<i>Examples</i>	<i>Risk Level</i>
<i>Customer-Facing</i>	<i>iPad kiosks, self-order terminals</i>	<i>P3</i>
<i>Payment Hardware</i>	<i>Shopify POS, Toast card readers</i>	<i>P4</i>
<i>IoT Kitchen Devices</i>	<i>Smart fryers (Model X9000), temp sensors</i>	<i>P4</i>
<i>Network Infrastructure</i>	<i>Cisco switches, Aruba WiFi APs</i>	<i>P3</i>

B. Audit Logging

<i>Log Type</i>	<i>Location</i>	<i>Captured Events</i>	<i>Retention</i>
<i>Access Logs</i>	<i>CloudWatch/Azure Monitor</i>	<i>Failed login attempts, admin actions</i>	<i>180 days</i>
<i>Transaction Logs</i>	<i>PostgreSQL DB</i>	<i>Order modifications, refunds, coupon redemptions</i>	<i>2 years</i>
<i>IoT Device Logs</i>	<i>Splunk OT Monitoring</i>	<i>Temp fluctuations, firmware update attempts</i>	<i>90 days</i>
<i>POS Activity</i>	<i>Toast POS Analytics</i>	<i>Payment processing errors, voided transactions</i>	<i>1 year</i>

Definitions

Breach:

A security incident where unauthorized individuals access, disclose, or steal Protected Data (P3/P4) requiring notification under GDPR, CCPA, or PCI DSS.

Example: POS system compromise exposing customer credit card numbers.

Event:

Observable occurrences in digital systems that may indicate anomalies:

- Unusual login attempts from unrecognized devices
- IoT devices transmitting abnormal data volumes (e.g., smart fryer sending 10GB hourly)
- Unexplained order modifications or coupon redemptions

Security Incident:

Events violating security policies with potential operational/financial impact:

Unauthorized access to P4 data (e.g., health inspection reports, payment details)

Ransomware encrypting recipe databases or inventory systems

API exploits generating 1,000+ fraudulent mobile orders

III. System Contacts

The Incident Response Team for the Fast Food Restaurant Digital Systems includes the following key personnel:

Incident Handler:	
Email Address:	
Phone Number:	

Service Manager:	
Email Address:	
Phone Number:	

The **Incident Handler** is a security contact who has technical knowledge of the application/system and full understanding of the Security Incident Response Plan.

All suspicious events reported by end users of the application/system should be directed to the *Incident Handler*. There must be clear and easily accessible documentation for end users of the application/system to contact the *Incident Handler* to report any suspicious events.

The [Service Manager](#) is an authority/decision maker for the application/system who understands the business impact of the system and its unavailability. The [Resource Proprietor](#) should take on the responsibilities of the Resource Manager or designate a qualified staff member for this role.

IV. Incident Response Procedures

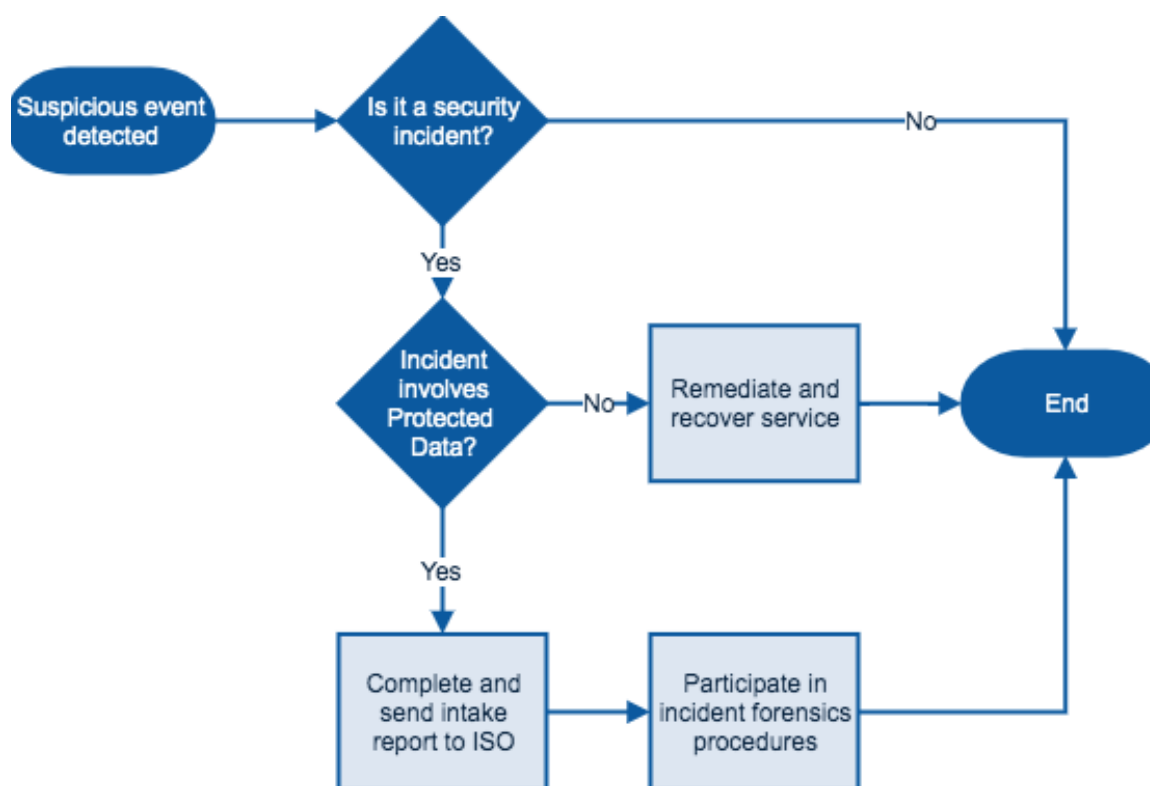


Fig 1. High Level Incident Response Workflow

The high level incident response steps can be summarized in the flowchart above. The sections below outline detailed procedures for each step.

Step 1: Security Incident Confirmation

Assess whether an event constitutes a security incident.

Actions:

1. Interview Staff:
 - "Was an order collected without proper verification (e.g., missing receipt or order number)?"
 - "Are IoT devices reporting implausible metrics (e.g., freezer sensors indicating -20°F while product integrity is compromised)?"
2. Review Evidence:
 - Analyze mobile app logs for duplicate order pickups or unauthorized access.
 - Inspect IoT device network traffic for anomalies (e.g., abnormal data transmission volumes).
3. Document Findings:
 - Use the [Incident Log Template] to record observations and decisions.

Decision:

- Security Incident Confirmed: Proceed to Step 2.
- False Alarm: Document findings and escalate to IT support for non-malicious system disruptions (e.g., POS terminal malfunction).

Step 2: Assess Initial Impact

Determine potential exposure of sensitive data or critical systems.

Key Questions:

- Does the affected system store or process Payment Card Industry (PCI) Data Security Standard (DSS)-regulated information?
- Could compromised IoT devices violate FDA food safety guidelines (e.g., temperature control failures)?
- Are customer loyalty accounts or personally identifiable information (PII) at risk?

Data Classification:

Level	Examples
P4	Credit card data, health inspection records
P3	Employee schedules, API keys, loyalty program data

Outcome:

- P3/P4 Data Involved: Escalate to the Information Security Office (ISO) (Step 3).
- No P3/P4 Data: Proceed to Remediation (Step 5).

Step 3: Escalate to ISO

Formal reporting protocol for incidents involving sensitive data.

Incident Intake Report Template:

1. Primary Contact: [Name], [Role], [Phone]
2. Affected Systems:
 - Device Type: POS Terminal #5 (IP: 192.168.1.5)
 - IoT Device: Smart Fryer #3 (Serial: XF-9000)
3. Data at Risk:
 - 50 PCI DSS-regulated payment records
4. Incident Summary:
 - "Unauthorized firmware update detected on IoT kitchen equipment."

Submit to: security-escalation@organization.com (example mail id)

Critical Protocol:

- Do not alter the state of affected systems (e.g., rebooting devices) until authorized by ISO.

Step 4: Support ISO-Led Investigation

Collaborate to preserve evidence and determine breach scope.

Tasks:

- Capture network traffic logs from compromised IoT devices.

- Secure backups of transaction logs and system snapshots.
- Assist ISO in identifying access to:
 - Proprietary operational data (e.g., recipe databases).
 - Customer geolocation or payment information.

Step 5: Remediation

Restore systems to a secure operational state.

Incident-Specific Remediation:

Incident Type	Remediation Steps
Mobile Order Fraud	Enforce multi-factor verification (e.g., QR codes) at pickup.
Ransomware on POS	Isolate terminal; restore from encrypted backups.
IoT Device Compromise	Physically disconnect and manually reset devices.
Phishing Attack	Revoke compromised credentials; block malicious domains.

Post-Remediation Actions:

- Patch systems per MSSEI standards.
- Conduct staff training on security protocols (e.g., secure credential management).

Incident Response Team

Role	Responsibilities	Contact Information
Incident Handler	Lead technical containment and forensic analysis.	
Service Manager	Authorize system downtime and resource allocation.	
Communications Lead	Manage stakeholder/customer notifications.	

Audit Logging Standards

Log Type	Purpose	Retention Period
POS Transactions	Track payment errors and cancellations.	1 Year
IoT Device Logs	Monitor firmware updates and operational commands.	90 Days
User Authentication	Flag unauthorized login attempts.	6 Months

Continuous Improvement

Conduct biannual simulated incident response exercises to:

1. Test response protocols for IoT device breaches or payment system compromises.
2. Train staff on identifying phishing attempts and social engineering tactics.
3. Refine communication workflows between technical, operational, and PR teams.